BEZPIECZEŃSTWO SYSTEMÓW TELEINFORMATYCZNYCH

Dr Hab. Inż. Mieczysław Jessa, prof. PP

Politechnika Poznańska,
Wydział Informatyki i Telekomunikacji,
ul. Polanka 3 (pok. 125), 61-131 Poznań, Poland
tel.: +48 61 665 38 54, fax: +48 61 665 38 30
e-mail: mieczyslaw.jessa@put.poznan.pl

Zakres merytoryczny przedmiotu:

Część I:

Zagrożenia dla danych przesyłanych i przetwarzanych w systemie teleinformatycznym

Część II:

Administracyjne metody ochrony danych

Część III:

Kryptograficzne metody ochrony danych

Część I

Zagrożenia dla danych przesyłanych i przetwarzanych w systemie teleinformatycznym

1. Podstawowe wymagania stawiane systemom teleinformatycznym
2. Atrybuty bezpieczeństwa informacji
3. Klasyfikacja zagrożeń
4. Kategorie zagrożeń
5. Przykłady zagrożeń dla sieci rozległych

Podstawowe wymagania stawiane systemom teleinformatycznym

- **Sprawność techniczna**
  - jakość projektu systemu,
  - jakość użytego sprzętu,
  - poprawność instalacji i eksploatacji.
- **Wydajność**
  - szybkość pracy urządzeń węzłowych,
  - przepływność strumieni wymienianych między urządzeniami, w szczególności w relacjach międzywęzłowych,
  - algorytmy sterujące przetwarzaniem informacji w urządzeniach węzłowych,
  - algorytmy sterujące transmisją informacji między urządzeniami w węźle oraz między węzłami sieci.
  - wydajność systemów zarządzania.

Podstawowe wymagania stawiane systemom teleinformatycznym

- **Odporność na uszkodzenia i ataki**
  - Odporność na celowe uszkodzenia fizyczne lub programowe elementów systemu.
  - Odporność na zmianę funkcji elementów systemu.
  - Odporność na blokowanie pracy elementów systemu (na blokowanie przepływu lub przetwarzania informacji).
  - Odporność na przejęcie kontroli nad fragmentami lub nad całą siecią telekomunikacyjną operatora.
  - Odporność (przeżywalność) w warunkach katastrof (pożar, powódź itp.).

Podstawowe wymagania stawiane systemom teleinformatycznym

Bezpieczeństwo teleinformatyczne (ang. Information Communication Technology Security – ICT security) możemy określić jako zespół procesów, których celem jest zdefiniowanie, osiągnięcie oraz utrzymanie atrybutów bezpieczeństwa. Do podstawowych atrybutów bezpieczeństwa należą:

- poufność (ang. confidentiality),
- integralność (danych, systemu) (ang. data, system integrity),
- dostępność (kontrolę dostępu) (ang. availability),
- uwierzytelnianie (ang. authentication),
- niezaprzeczalność (ang. nonrepudiation),
- niezawodność (ang. realiability),

Atrybuty bezpieczeństwa informacji

Poufność oznacza niedostępność treści zawartej w danych dla wszystkich podmiotów nie uprawnionych do jej odczytania. Danym, których naruszenie poufności byłoby szczególnie niewskazane i kosztowne, przypisuje się odpowiedni wysoki poziom bezpieczeństwa (ochrony), np. poufne, tajne, ściśle tajne. Podstawowym sposobem zapewnienia poufności danych jest szyfrowanie. Inne środki takie jak, np. ograniczenie fizycznego dostępu (podział na strefy), podział uprawnień użytkowników, utajnianie transmisji, maskowanie sygnału itp. mają charakter pośredni. Ponieważ nie można wykluczyć chociażby przypadkowego dostępu do danych, system ochrony poufności powinien gwarantować wykrycie **każdorazowego nieuprawnionego dostępu do danych**.

Atrybuty bezpieczeństwa informacji

Integralność ***danych*** oznacza, że dane nie zostaną w nieuprawniony sposób zmienione, także wymazane (celowo – świadome działania nieuprawnionego użytkownika, Przypadkowo – zakłócenia, błędy transmisji, błędy oprogramowania itp.). Integralność zapewnia się stosując funkcję skrótu, a w pewnym stopniu także kody wykrywające i korygujące błędy. Inne działania o charakterze pośrednim to uwierzytelnianie, ograniczenie fizycznego dostępu (podział na strefy), podział uprawnień użytkowników, stosowanie metod, sprzętu i oprogramowania zwiększającego niezawodność systemu, tolerancję na błędy, odporność na warunki środowiskowe, na wykrycie transmisji itp.

Integralność ***systemu*** oznacza właściwość polegającą na tym, że system realizuje zamierzone funkcje w nienaruszony sposób, niezależnie od działań zewnętrzych, losowych lub zamierzonych.

Atrybuty bezpieczeństwa informacji

Dostępność (*kontrola dostępu*) oznacza brak ograniczeń w korzystaniu z danych przez uprawnionych (**autoryzowanych**) użytkowników. Zasoby powinny być dostępne i możliwe do wykorzystania na żądanie i w założonym czasie.
Naruszenia w dostępności danych mogą wystąpić na skutek działań osób trzecich, działań uprawnionego użytkownika lub przypadkowo (np. awarie). Wstrzymanie dostępności uprawnionego użytkownika do zasobów jest często wstępem do ataku na poufność lub integralność danych. Może być także celem samym w sobie. W rezultacie pożądanym jest **zapewnienie wykrycia każdorazowej próby nieuzasadnionego dostępu do danych**. Dostępność danych jest zapewniana przez odpowiedniej jakości sprzęt i oprogramowanie, zabezpieczone systemy operacyjne, przez stały nadzór nad stopniem wykorzystania zasobów, przez monitorowanie ruchu w sieci oraz obciążenia serwerów.

Atrybuty bezpieczeństwa informacji

Uwierzytelnianie danych oznacza, że odbiorca ma pewność, że dane nie zostały „podrzucone” przez nieuprawnione osoby. W kontekście urządzeń uwierzytelnienie oznacza, że dane zostały dostarczone/wytworzone przez konkretne urządzenie – źródło danych.

Pojęcie uwierzytelniania jest często łączone z pojęciem *rozliczalności* (ang. accountability) czyli z właściwością polegającą na tym, że działania podmiotu mogą być jednoznacznie przypisane tylko temu podmiotowi).

Niezaprzeczalność oznacza, że nadawca danych nie może się wyprzeć faktu ich nadania lub udostępnienia.

Niezawodność oznacza brak ograniczeń w dostępie do danych przez określony procent czasu eksploatacji systemu dla uprawnionych użytkowników, w rzeczywistych warunkach pracy systemu.

Atrybuty bezpieczeństwa informacji

Uzupełnieniem atrybutów bezpieczeństwa są takie pojęcia jak:

- Wrażliwość informacji (ang. data sensibility) – miara, najczęściej jakościowa (niska, średnia, wysoka), przypisana informacji przez autora lub dysponenta. Celem jest przydzielenie danej informacji adekwatnych środków ochrony.
- Usługa krytyczna (ang. critical service) – jest to usługa realizowana przez system teleinformatyczny, mająca bezpośrednie znaczenie dla funkcjonowania instytucji i wskazana przez zespół odpowiedzialny za bezpieczeństwo (zob. „Administracyjne metody ochrony danych) w celu zapewnienia jej szczegółowej ochrony.
- Proces krytyczny (ang. critical process) – jest to proces związany z działaniem firmy/systemu, który podlega szczególnej ochronie ze względu na następstwa jego wadliwego działania.
- Zabezpieczenie (ang. Safeguard) – to procedura, działanie, mechanizm lub praktyka, której celem jest zredukowanie ryzyka utraty atrybutów bezpieczeństwa informacji (zob. „Administracyjne metody ochrony danych).

Klasyfikacja zagrożeń

Definicja 1

Podatność (ang. *vulnerability)* to wada lub luka w strukturze fizycznej, organizacji, procedurach, personelu, zarządzaniu, administrowaniu, sprzęcie lub oprogramowaniu, która może być wykorzystana do spowodowania szkód w systemie teleinformatycznym lub działalności użytkownika.

Definicja 2

Zagrożenie (ang. *threat)* to potencjalne naruszenie zabezpieczenia systemu informatycznego.

W rozszerzonej definicji zagrożeń przyjmujemy, że zagrożenia to potencjalne działania człowieka (lub zaniechanie takich działań) albo sił wyższych, dotyczące bezpośrednio zasobu teleinformatycznego lub organizacji procesu przetwarzania informacji i mogące (po wykorzystaniu podatności, jeśli istnieje) spowodować, *w zależności od konkretnego atrybutu bezpieczeństwa*, straty proporcjonalne do wagi procesu krytycznego, wspieranego przez ten proces i wykorzystywane w nim zasoby.

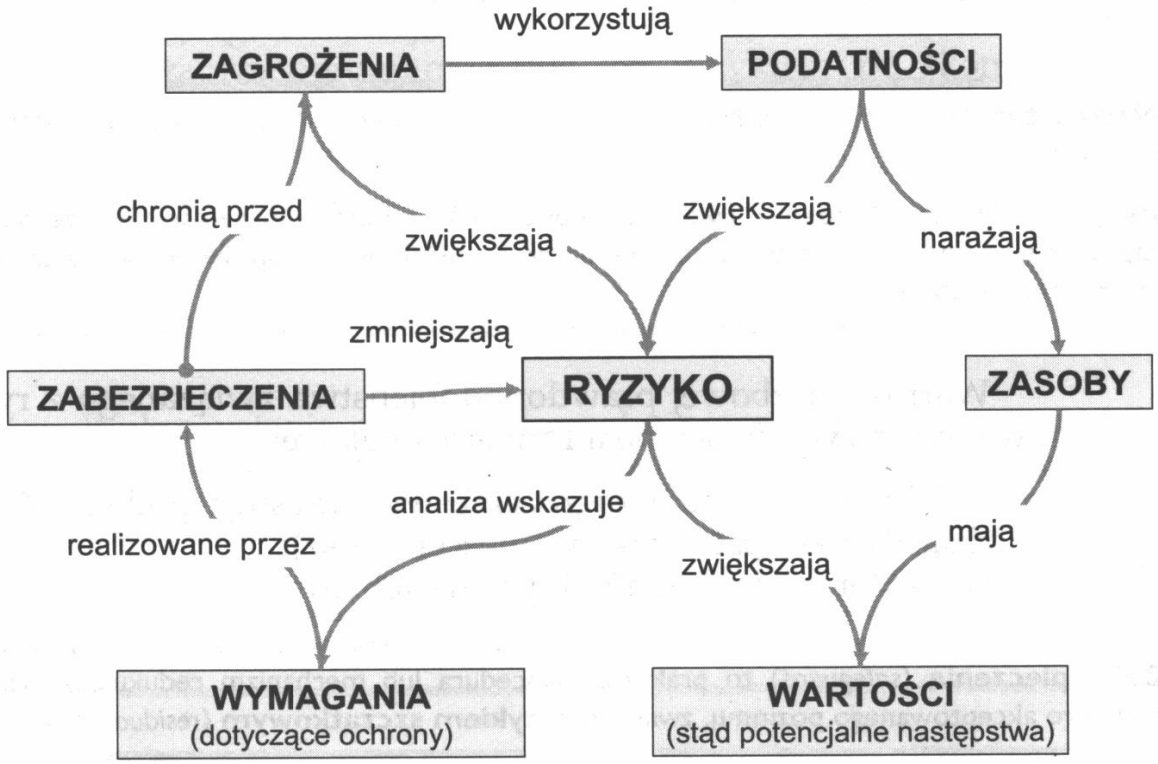
Identyfikacja zagrożeń jest wstępną czynnością w analizie ryzyka i podatności.

Klasyfikacja zagrożeń

Jednym z częściej spotykanych **błędów** w rozumowaniu jest myślenie, że środki ochronne wyeliminują zagrożenia. Takie stwierdzenie jest nieporozumieniem, bo **nie mamy wpływu na zagrożenia.** Jedyne, co możemy zrobić, aby zachować w takiej sytuacji ciągłość działania systemów teleinformatycznych, **to zlikwidować podatność (a nie zagrożenie)**. Podobnie nie mamy wpływu na próby (zagrożenie) jakiegoś intruza, np. z Indonezji, włamania się do naszych systemów. Możemy natomiast, przez odpowiednią konfigurację systemu i urządzeń sieciowych oraz bieżącą instalację uaktualnień, **zminimalizować podatności** pozwalające na skuteczny atak.

Podsumowując - możemy jedynie zminimalizować (czasami uda się też zlikwidować) podatności, które mogłyby być wykorzystane przez zagrożenia. **Innymi błędami** (na które należy zwrócić szczególną uwagę podczas identyfikacji zagrożeń) jest mylenie samego zagrożenia z jego przyczyną i skutkami, zagrożenia z podatnością oraz zagrożenia z jego realizacją.

Klasyfikacja zagrożeń



Relacje między elementami bezpieczeństwa [1]

Klasyfikacja zagrożeń

Definicja 3

Incydentem naruszenia bezpieczeństwa teleinformatycznego nazywamy każde zrealizowane zagrożenie.

Incydentem naruszenia bezpieczeństwa systemu teleinformatycznego jest każde zdarzenie, które:

- umożliwia lub stanowi nieuprawniony dostęp do informacji przetwarzanej, przesyłanej i przechowywanej w systemie teleinformatycznym,
- umożliwia lub powoduje utratę jej tajności, integralności i/lub dostępności.

Należy jednak pamiętać, że **nie każdy incydent (naruszenia zasad lub systemu bezpieczeństwa teleinformatycznego) jest atakiem**. Atakiem nie jest na przykład:

- zniszczenie komponentów elektronicznych systemu na skutek wyładowania atmosferycznego;
- zniszczenie klawiatury stacji roboczej przez operatora, np. z powodu wylania na nią kawy;
- unieruchomienie systemu komputerowego z powodu usterki sprzętowej w kluczowym komponencie itd.

Klasyfikacja zagrożeń

Uwaga 1

Uświadomienie osobom prowadzącym identyfikację i analizę zagrożeń, że nie każdy incydent naruszenia bezpieczeństwa jest atakiem jest niezmiernie istotne, ***ponieważ często widzi się zagrożenia wyłącznie przez pryzmat ataków*****. Takie podejście prowadzi do błędów w ocenie zagrożeń i w konsekwencji do budowy „dziurawych" systemów bezpieczeństwa.**

Uwaga 2

Nie każdy incydent z zakresu bezpieczeństwa teleinformatycznego jest ***przestępstwem w rozumieniu polskiego prawa*** *(ale każde przestępstwo komputerowe jest incydentem)*, tzn. nie każdym incydentem zajmie się policja i prokuratura. Ustalenie, czy intruz wykorzystywał zautomatyzowane narzędzia hakerskie, czy luki w oprogramowaniu lub konfiguracji serwera albo sieci, jest istotne przy określaniu, czy sprawca, wykonując określone działania, wypełnił ustawowe znamiona przestępstwa.

„Kto, nie będąc do tego uprawnionym, przez transmisję, zniszczenie, usunięcie, uszkodzenie lub zmianę danych informatycznych, w istotnym stopniu zakłóca pracę systemu komputerowego lub sieci teleinformatycznej, podlega karze pozbawienia wolności od 3 miesięcy do lat 5" (art. 269a. KK)

Klasyfikacja zagrożeń

W analizie zagrożeń wprowadza się także pojęcie **„istotności" zagrożenia.** Zależy ona od:

A. W wypadku celowego zagrożenia spowodowanego przez człowieka:

- atrakcyjności zasobu,
- łatwości zamiany zdobytego zasobu w zysk,
- umiejętności technicznych intruza (ten czynnik a priori jest osobom prowadzącym analizę nieznany, więc rozsądne jest przyjąć, że w każdym wypadku te umiejętności są duże);

B. Możliwości (w sensie potocznie rozumianego prawdopodobieństwa) realizacji zagrożenia:

- ogólnie pojętej „kultury pracy" w analizowanej organizacji,
- środowiska (np. czy firmie zagrażają wstrząsy sejsmiczne, czy teren umożliwia skryte podejście itd.),
- stosowanych środków ochronnych,
- wrażliwości podatności, zarówno technicznej, jak i pozatechnicznej, na wykorzystanie

Klasyfikacja zagrożeń

Wyróżnia się dwa ogólne podejścia do identyfikacji zagrożeń:

1. **Sterowane podatnościami** (ang. *vulnerability-driven*) - wymaga zidentyfikowania wszystkich możliwych podatności. Warto zauważyć, że taka identyfikacja następuje podczas audytu bezpieczeństwa teleinformatycznego.

2. **Sterowane zasobami** (ang. *asset-driven*) - wymaga przeglądu kolejno wszystkich zasobów i identyfikowania, co może narazić zasób lub przetwarzaną (przesyłaną, przechowywaną) w nim informację na utratę tajności, integralności lub dostępności. Jest to podejście stosowane najczęściej w **analizie ryzyka** na potrzeby bezpieczeństwa teleinformatycznego.

Jedną z czynności mających kluczowy wpływ na powodzenie identyfikacji zagrożeń **jest dobór osób do zespołu identyfikującego**. W jego skład będą wchodzili analitycy badający ryzyko oraz główni zainteresowani z firmy poddawanej analizie. Termin **„główni zainteresowani”** odpowiada stosowanemu w projektowaniu systemów teleinformatycznych terminowi **„udziałowcy”.** Będą to osoby, na których działalność służbową ma wpływ funkcjonowanie analizowanych systemów teleinformatycznych, w szczególności incydenty i błędy popełnione w ochronie informacji przetwarzanych, przesyłanych i przechowywanych w tych systemach.

Klasyfikacja zagrożeń

Podatności, a więc wady lub luki mogą być związane z:

1. Systemem ochrony:

- elementami ochrony fizycznej: elementami mechanicznymi i budowlanymi, ludźmi pełniącymi funkcje ochronne (straż przemysłowa, portierzy), procedurami ochrony fizycznej;
- elementami skomputeryzowanego systemu ochrony technicznej: elementami sprzętowymi, elementami programowymi, ludźmi eksploatującymi skomputeryzowany system ochrony technicznej;
- systemem nadzoru: ludźmi pełniącymi funkcje nadzorcze, procedurami nadzoru;
- elementami sprzętowo-programowymi wbudowanymi lub dodanymi do systemu informatycznego w celu zapewnienia należytej ochrony informacji, takimi jak zapory sieciowe, systemy uwierzytelniania i autoryzacji w systemach dostępu logicznego, oprogramowanie antywirusowe, oprogramowanie i urządzenia kryptograficzne itp.;

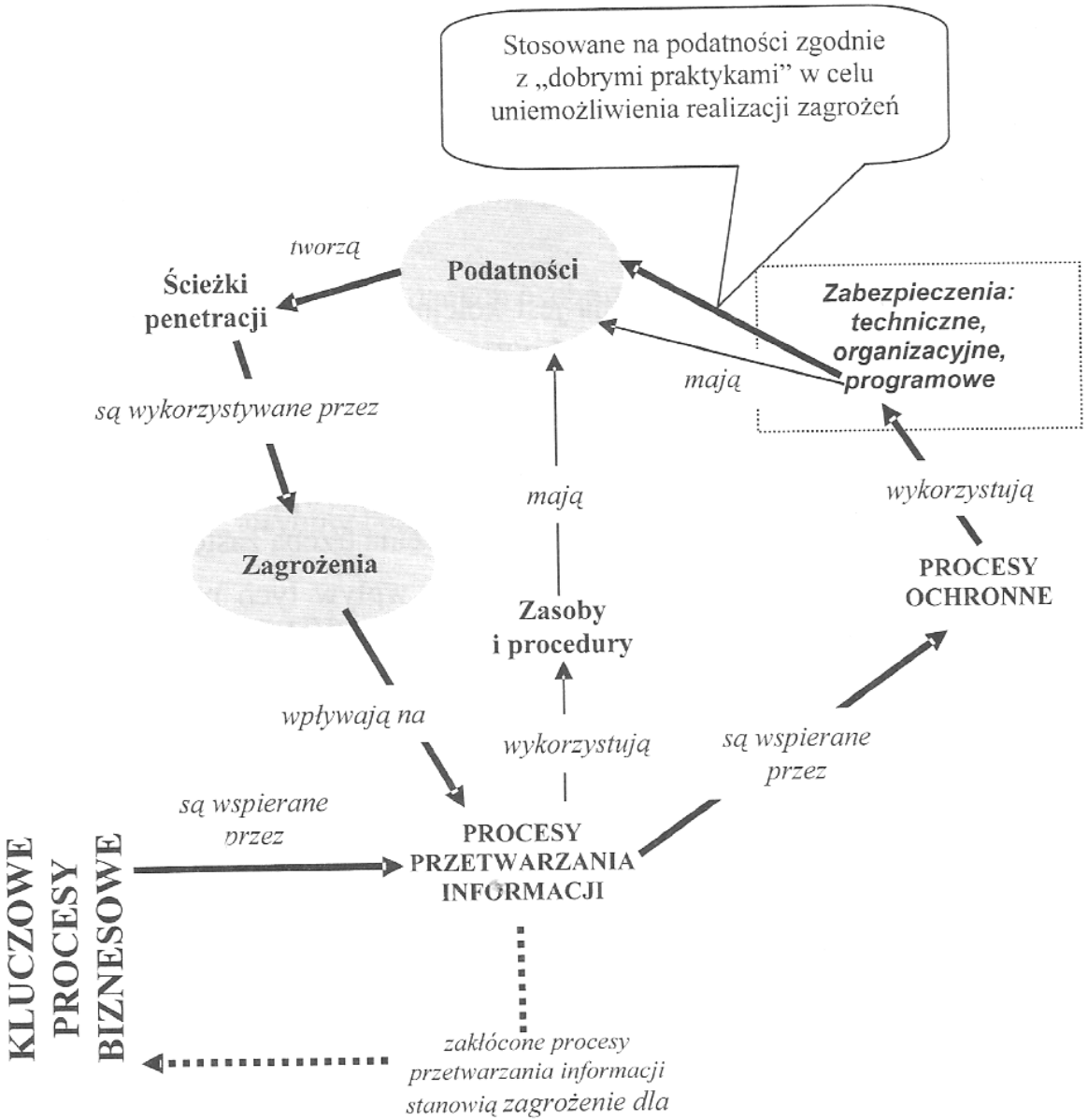
Klasyfikacja zagrożeń

2. Środowiskiem eksploatacji (otoczeniem) systemu informatycznego i związanego z nim systemu ochrony:

- systemami zasilania w energię elektryczną,
- systemami klimatyzacji,
- budynkami i pomieszczeniami

3. Systemem teleinformatycznym:

- elementami sprzętowymi: składającymi się na system komputerowy, zapewniającymi komunikację między systemami i sieciami (tzw. urządzenia sieciowe);
- elementami programowymi: systemem operacyjnym, oprogramowaniem użytkowym;
- ludźmi eksploatującymi system komputerowy: operatorami, administratorami;
- procedurami eksploatacji (w szczególności procedurami dostępu do systemu oraz do informacji przetwarzanej i przechowywanej w systemie);



Zależności przyczynowo-skutkowe w procesie identyfikacji procesów, zagrożeń, podatności i zabezpieczeń [2]

Klasyfikacja zagrożeń

Zagrożenia uraty poufności

Celem ataków na poufność informacji jest uzyskanie dostępu do danych użytkownika. Etapem pośrednim często bywa uzyskanie dostępu do danych **sygnalizacyjnych** (tj. czas, częstość i długość połączeń) lub zarządzających. Jako zagrożenia utraty poufności wymienia się:

- przechwycenie przesyłanych danych (*eavesdropping*): użytkownika, sygnalizacyjnych, na interfejsie uwierzytelniającym,
- podszywanie się (*masquerading*) pod urządzenia sieci obsługującej, pod adresata danych przesyłanych na interfejsie uwierzytelniajcym,
- analizę ruchu (*traffic analysis*) pasywną, aktywną.
- uzyskanie nieuprawnionego dostępu do danych (*unauthorised access to data*) przechowywanych w systemie, w pamięci terminala, na karcie np. USIM.
- uzyskanie informacji o lokalizacji użytkownika na podstawie danych sygnalizacyjnych (*compromise of location information*).

Klasyfikacja zagrożeń

Zagrożenia utraty integralności

Utrata integralności polega na modyfikacji danych, dołączeniu nowych danych, kilkukrotnym powtórzeniu przesyłanych danych oraz usunięciu części lub całości informacji. Na zagrożenia tego typu składają się zarówno potencjalne ataki, jak również zwykłe błędy transmisyjne, których skutkiem nastąpiła modyfikacja:

- danych użytkownika,
- danych sygnalizacyjnych lub sterujących,
- danych za pomocą podszywania się pod uczestnika transmisji,
- danych i aplikacji w terminalu,
- danych i aplikacji na kartach np. w telefonie,
- danych przesyłanych na interfejsach,
- danych przechowywanych w systemie,
- zachowania terminala lub karty np. telefonu.

Klasyfikacja zagrożeń

Zagrożenia związane z uwierzytelnianiem

Skutkiem udanego ataku na procedury uwierzytelniania jest możliwość dostarczenia fałszywych danych odbiorcy. W rezultacie atakujący może wprowadzić w błąd odbiorcę, który podejmie działania oczekiwane przez atakującego, na przykład dokona rekonfiguracji sieci, chociaż nie jest to potrzebne. Błędy ludzkie, błędy transmisyjne oraz inne modyfikacje, wymienione dla integralności danych wymagają ponownego uwierzytelnienia źródła wiadomości.

Zagrożenia związane z niezaprzeczalnością

Skuteczny atak na niezaprzeczalności powoduje, że nadawca może się wyprzeć faktu nadania wiadomości lub np. faktu podpisania konkretnej umowy. Ataki dotyczą funkcji kryptograficznych zapewniających ten atrybut bezpieczeństwa.

Klasyfikacja zagrożeń

Zagrożenia utraty dostępności

Skutkiem udanego ataku na dostępność systemu jest obniżenie jakości świadczonych usług lub uniemożliwienie ich świadczenia poprzez spowodowanie nieprawidłowości w transmisji danych: zarządzających, użytkownika, bądź sygnalizacyjnych. Klasyfikacja zagrożeń utraty dostępności obejmuje: ingerencje fizyczne, ingerencje na poziomie protokołów, podszywanie się pod uprawnionych użytkowników, nadużycia usług alarmowych.

- Do ataków spowodowanych ingerencją fizyczną zalicza się m.in. zakłócanie, przecięcie przewodów, spowodowanie nieprawidłowości w systemie zasilania, opóźnianie transmisji.
- Ataki na poziomie protokołów bazują na sztucznym spowodowaniu lub spotęgowaniu nieprawidłowości przewidzianych przez projektantów sieci. Przyczyną trudności związanych z protokołami mogą być również fizyczne uszkodzenia sieci.
- Nadużycia usług alarmowych mogą mieć miejsce, gdy operator umożliwi realizację połączeń alarmowych wyłącznie za pomocą terminala (np. bez karty USIM). Skutkiem tego typu nadużyć może być sparaliżowanie lokalnego centrum alarmowego.

Kategorie zagrożeń

Użytkownicy

Dwie podstawowe kategorie zagrożeń **osobowych** to:

- zagrożenia wewnętrzne (pracownicy, dostawcy, konsultanci, klienci, byli pracownicy, stażyści)
- zagrożenia zewnętrzne (agenci obcych wywiadów, terroryści, kryminaliści, agenci wywiadu gospodarczego, hakerzy o różnej motywacji).

Z badań wynika, że większość incydentów związanych z bezpieczeństwem ma swoje źródło **wewnątrz** organizacji. Wśród zagrożeń wewnętrznych wyróżniamy:

- akty wewnętrznego sabotażu,
- kradzież informacji,
- kradzież usług (wykorzystanie systemu do celów prywatnych, do których nie został on stworzony, np. gry, prywatna poczta, instalowanie prywatnego oprogramowania itp.),
- błędy użytkowników (np. przy wprowadzaniu danych, w użytkowaniu systemu),
- niedbalstwo (np. brak odpowiedniej ochrony antywirusowej, brak lub niekompletność kopii zapasowych plików,
- nieprawidłowe stosowanie mechanizmów zabezpieczeń (np. nieprawidłowości w korzystaniu z systemu haseł – ujawnianie haseł innym osobom, identyczne hasła do wielu systemów, zapisywanie haseł w miejscach ogólnie dostępnych, trywialna struktura haseł, itp.).

Kategorie zagrożeń

Podstawowe ataki na system realizowane przez użytkowników z wewnątrz lub z zewnątrz systemu teleinformatycznego odbywają się najczęściej przez przechwycenie identyfikatora i hasła użytkownika uprawnionego. W tym celu stosowane są różne metody. Są to na przykład:

- zmiana oryginalnego programu, którym użytkownicy rejestrują się w systemie – podstawienie konia trojańskiego,
- wykorzystanie rezydentnych programów kontrolujących klawiaturę – zapisywanie sekwencji naciskanych klawiszy,
- podsłuch łącza, którym transmitowane są dane uwierzytelniające (rozgałęźnik na kablu klawiatury, kablu sieciowym, podsłuch w lokalnej sieci komputerowej, podsłuch w sieci rozległej, podgląd optyczny),
- atak słownikowy – przeszukiwanie pewnego słownika (podstawianiu w miejsca hasła ciągów znaków z pewnego słownika; ochroną – niekoniecznie zawsze niewystarczającą, jest automatyczne blokowanie konta po kilkukrotnym podaniu błędnego hasła),
- przeszukiwanie wyczerpujące metodą prób i błędów – atak brutalny (podobne do metody poprzedniej, lecz tutaj podstawiamy wszystkie możliwe ciągi),
- **metody inżynierii społecznej (socjotechnika)** – nakłonienie użytkownika do udostępnienia lub zmiany hasła.

Ataki są poprzedzane zazwyczaj zbieraniem informacji o atakowanym obiekcie oraz o jego użytkowniku. Podstawowe sposoby zdobywania informacji to:

- zbieranie i analiza dokumentów publicznie dostępnych, w szczególności tych zawierających informacje o używanych systemach operacyjnych i środkach ochrony, stosowanym sprzęcie komputerowym,
- podstęp – udawanie pracownika, dostawcy, czasami przyjaciela pomagającego w trudnej sytuacji, w celu uzyskania informacji, o które się zabiega,
- wymuszenia, szantaż,
- przeszukiwanie odpadków w siedzibie instytucji oraz poza jej terenem,
- zaoferowanie na atrakcyjnych warunkach swoich usług, np. serwisowych, utylizacji odpadów, itp.
- wykorzystanie zasobów, które mogą być współdzielone razem z użytkownikiem uprawnionym (tzw. ukryty kanał) z pominięciem systemów zabezpieczeń (np. z tego samego serwera lokalnego czy WWW),
- formułowanie zapytań do udostępnionej części danych, ujawniających informacje o danych tajnych (tzw. pośredni dostęp do danych, obejmuje także ankiety),
- analiza odpowiedzi systemu na próby wprowadzenia nowych danych,
- wykorzystanie zależności matematycznych pomiędzy danymi jawnymi i tajnymi (np. zaszyfrowanymi),
- korzystanie z metod statystycznych (np. częstości występowania liter, imion z uwzględnieniem statystyki danego języka itp.)

Kategorie zagrożeń

Emisja ujawniająca

Zjawisko niepożądanej emisji sygnałów elektromagnetycznych jest nazywane emisją ujawniającą. Wyróżniamy emisję ujawniającą bezprzewodową i przewodową. Ta ostatnia obejmuje także przekazywanie sygnałów elektrycznych w sieci zasilającej, w uziemieniach, w obwodach sygnałowych itp.

Awarie

Awarie mogą mieć charakter losowy lub nielosowy. W tym ostatnim przypadku mogą wynikać z działań świadomych (ataki) lub nieświadomych (błędy w projekcie, nieodpowiednia jakość wykonania, niewłaściwa eksploatacja, zbyt długa eksploatacja). Jeżeli wykluczymy działania świadome, to dla dowolnego **obiektu** (podstawowe pojęcie teorii niezawodności) możemy podać szereg pojęć, które charakteryzują jego niezawodność. Obiektem może być pojedyncze urządzenie np. komputer, ruter, abonent, lub na przykład sieć telekomunikacyjna realizująca usługę transportowa

Kategorie zagrożeń

Ponieważ skutki awarii mogą być bardzo różne, spośród posiadanych zasobów wyróżnia się tzw. **infrastrukturę krytyczną**, której wadliwe działanie **całkowicie blokuje możliwość świadczenia usług** istotnych dla przedsiębiorstwa, np. ISP (ang. Internet Service Provider).

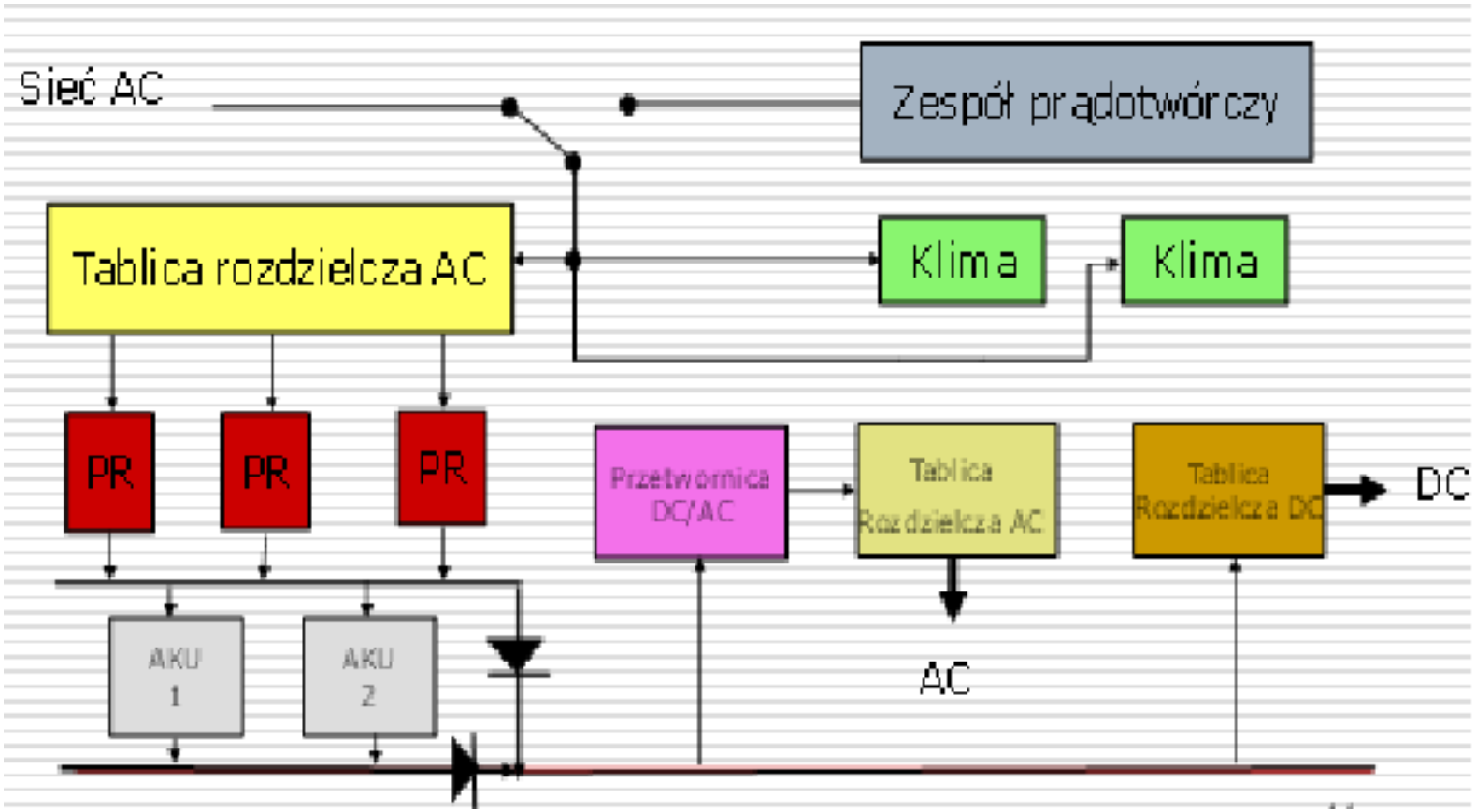
W systemach teleinformatycznych do infrastruktury krytycznej możemy zaliczyć:

- układy zasilania (skutki natychmiastowe),
- układy taktowania (skutki natychmiastowe lub opóźnione w czasie),
- układy wentylacji i klimatyzacji (skutki opóźnione w czasie, dotyczą części systemów)

W przypadku układów zasilania korzystamy z potrojonego zabezpieczenia, w przypadku układów taktowania z podwójnych zabezpieczeń, wentylacja i klimatyzacja jest dublowana w wybranych węzłach/centrach przetwarzania informacji.

Podana specyfikacja nie uwzględnia krytycznych elementów infrastruktury przestrzenno-budowlanej oraz systemów ochrony tej infrastruktury.

Kategorie zagrożeń



Schemat budowy siłowni DC obiektu teleinformatycznego o istotnym znaczeniu dla przedsiębiorstwa

Kategorie zagrożeń

Wnioski dla projektantów systemów teleinformatycznych wynikające z analizy awarii przeprowadzonych przez FCC (ang. *Federal Communication Commision*) w USA:

1. Przeciążenia systemów telekomunikacyjnych wykorzystywanych dla transmisji danych powodują poniżej 10% przerw w pracy ale powodują 40%-50% strat minut konsumentów. Jest to jednak **konsekwencją ustalenia przez daną firmę konkretnego stosunku dostępności sieci do ceny jej utworzenia**.

2. Konsekwencje błędów oprogramowania i uszkodzeń sprzętu są zbliżone.

3. Przerwy pracy spowodowane przez pracowników nie są głównym typem awarii, jednak są dominujące pośród tych, na które ma wpływ firma. Są źródłem ponad połowy incydentów i prawie dwóch trzecich spośród strat minut.

4. G**łówną przyczyną przerw w pracy sieci telekomunikacyjnej świadczącej usługi transmisji danych są przerwania kabli**. Stanowią one 70% - 80**% wszystkich awarii i jest to** to czynnik dominujący. Do przecięcia kabli przyczyniają się przede wszystkim firmy budowlane oraz firmy związane z szeroko pojętymi mediami (energetyczne, wodociągowe, kanalizacyjne).

5. Sposobem zmniejszenia strat firmy spowodowanych przez pracowników jest **odpowiedni dobór i szkolenie kadry**.

Przykłady zagrożeń dla sieci rozległych

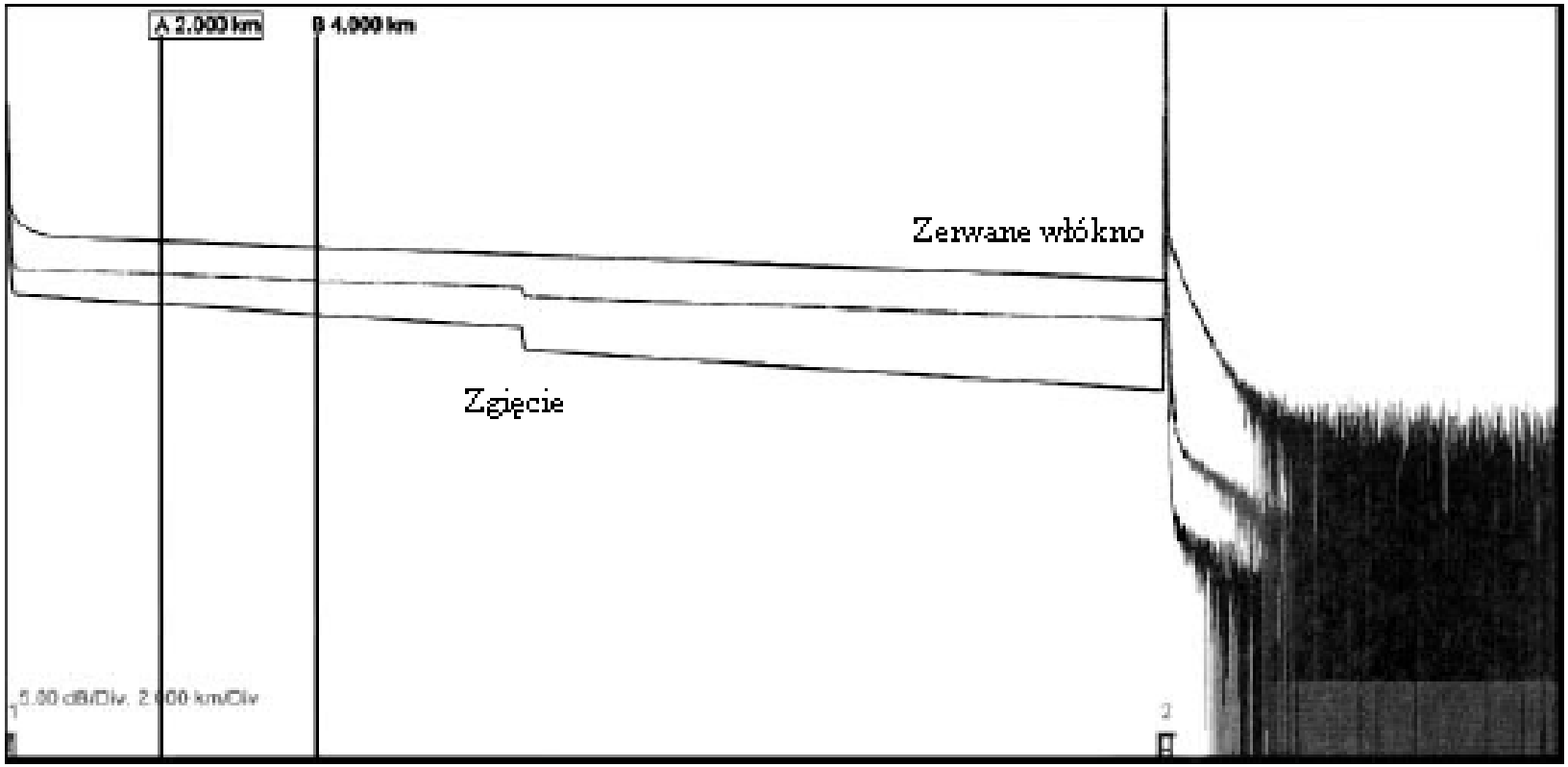
Ataki na kable światłowodowe

- przecięcie kabla (łatwe do wykrycia),
- podsłuch (trudny do wykrycia),
- zagłuszanie sygnału użytecznego (trudne do wykrycia),

Wymienione ataki mogą być połączone z celową blokadą dostępu do miejsc atakowanych np. wybór bagna na miejsca ataku, zalanie studzienki betonem, zimą wodą, blokowanie miejsca dostępu np. samochodem itp.

Można także świadomie opóźniać naprawę, tak aby usuniecie skutków ataku musiało być poprzedzone np. wizytą policji, prokuratora czy ubezpieczyciela.

Przykłady zagrożeń dla sieci rozległych



Wynik pomiaru reflektometrem OTDR (*Optical Time Domain Reflectometer)* dla długości fal: 1310nm, 1550nm, 1625nm. Widoczne zdarzenia zgięcie i koniec włókna

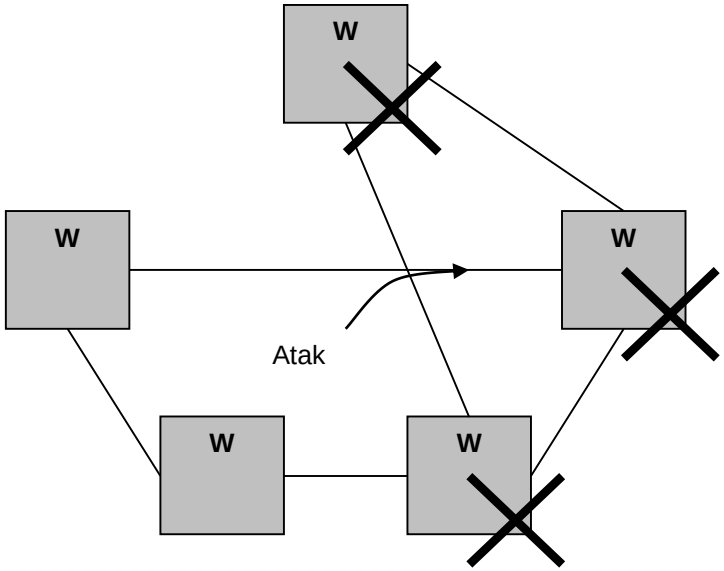
Przykłady zagrożeń dla sieci rozległych

Jeżeli *promień zgięcia jest mniejszy niż promień krytyczny* dla danej długości fali, część światła biegnącego włóknem nie ulega całkowitemu odbiciu i przenika przez płaszcz na zewnątrz. **Zjawisko takie występuje również w przeciwną stronę.** Taki atak wymaga wykopania kabla a następnie zidentyfikowania i wypreparowania odpowiedniego włókna. *W odróżnieniu od przecięcia nie jest to czynność, którą jest w stanie wykonać każdy przypadkowy człowiek.* Jednak osoba z odpowiednim doświadczeniem może to uczynić. Prostszym sposobem dostępu do włókna jest **otwarcie mufy** w studzience telekomunikacyjnej, gdzie dostępne są wypreparowane włókna. Kolejną trudnością, jaką musi pokonać intruz jest konieczność posiadania bardziej zaawansowanego sprzętu, mianowicie źródła światła laserowego wysokiej mocy o długości fali odpowiadającej długości fali kanału, który chcemy zakłócić.

Taki atak powoduje degradację przesyłanych informacji, ale w wypadku sieci czysto optycznej może również zakłócić inne łącza podłączone do łącza zaatakowanego. **Wprowadzenie sygnału w terenie, a nie w węźle sieci ma tą zaletę, że nie trzeba pokonywać praktycznie żadnych zabezpieczeń fizycznych, które występują w punktach gdzie instaluje się urządzenia telekomunikacyjne.** Nic nie stoi na przeszkodzie by ktokolwiek mógł nabyć mapę dowolnego terenu, zazwyczaj o skali 1:1000 czy nawet 1:500, w Ośrodku Dokumentacji Geodezyjno – Kartograficznej**.**

Przykłady zagrożeń dla sieci rozległych

Wykrycie ataku z wygięciem włókna nie jest tak łatwe jak w przypadku przecięcia kabla. Zwykły progowy czujnik mocy może nie dać jednoznacznej odpowiedzi co do miejsca ataku, gdyż dzięki brakowi regeneracji w sieciach optycznych alarm zostanie podniesiony w wielu węzłach, do których dotrą skutki ataku. Nie jest też pewne czy zakłócający sygnał przekroczy próg mocy, gdyż jest nawet możliwa sytuacja, że średnia moc spada (zob. atak na EDFA).

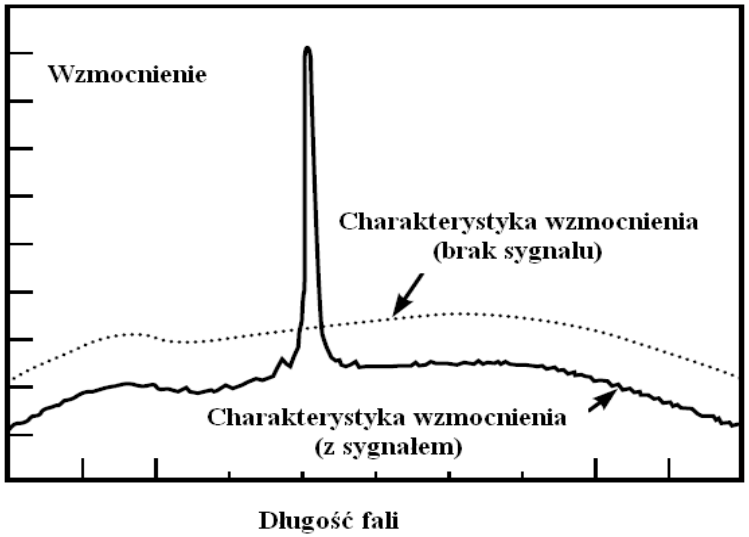


Zobrazowanie propagacji ataku w sieci optycznej

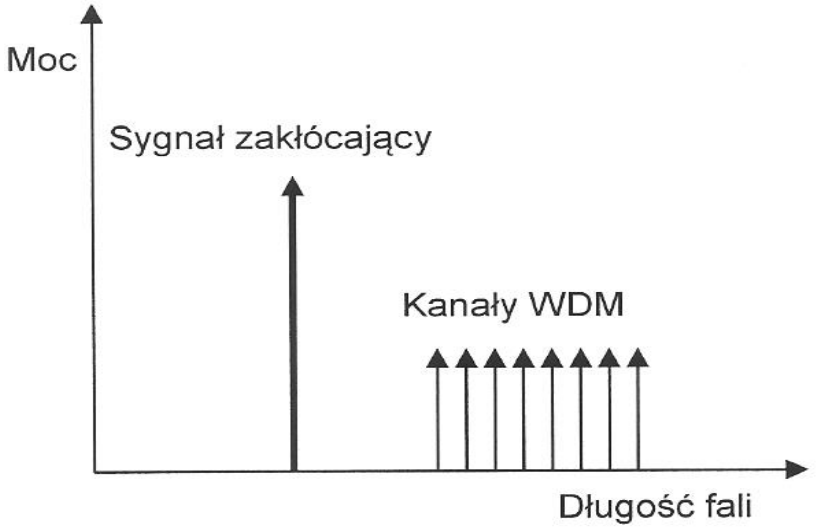
Przykłady zagrożeń dla sieci rozległych

Ataki na wzmacniacze optyczne

Włókniste wzmacniacze erbowe stosuje się obecnie powszechnie w sieciach światłowodowych dzięki temu, iż *oferują optyczną przeźroczystość i są niezależne od formatu sygnału przesyłanego*. **Niestety, ich unikalne właściwości czynią je również potencjalnym celem ataku spoza pasma transmisji** (*out-of-band jamming*). Jest możliwe wykorzystanie zależności wzmocnienia całego wzmacniacza od mocy sygnału wejściowego. Jeżeli sygnał wejściowy jest odpowiednio silny może znacząco obniżyć poziom inwersji nośników, a więc doprowadzić do spadku wzmocnienia.



Wpływ sygnału wejściowego na charakterystykę wzmocnienia



Ilustracja umieszczenia sygnału zakłócającego

Przykłady zagrożeń dla sieci rozległych

Ataki na wzmacniacze optyczne

- Współcześnie dostępne wzmacniacze mają na wejściach filtry **pasmowo-przepustowe**, których głównym zadaniem jest ograniczenie szumów na wejściu. Nie mają one wysokiej selektywności, jednak w zależności od położenia sygnału zakłócającego na osi częstotliwości, *mogą uniemożliwić lub utrudnić atak spoza pasma*. Intruz może jednak również przeprowadzić atak tą samą metodą, lecz w paśmie, czyli *nakładając się na kanały informacyjne,* ***czemu filtry wejściowe nie zapobiegną*** (taki atak jest łatwiejszy do wykrycia).
- Wzmacniacze EFDA charakteryzują się też specyficznymi właściwościami czasowymi. Jeżeli sygnał wejściowy zmienia się **bardzo szybko** w stosunku do czasów powrotu do podstawowego poziomu energetycznego jonów erbu, który wynosi typowo około 10 mikrosekund, wtedy wzmocnienie dla szerokopasmowego sygnału jest praktycznie stałe. **Jeżeli jednak zmienność sygnału (lub jego obwiedni) jest wyraźnie mniejsza niż czas deekscytacji, wtedy można zauważyć zmiany stopnia inwersji obsadzeń jonów erbu i w związku z tym również wzmocnienia.** Charakterystyczne jest to, że zmiana wzmocnienia występuje dopiero po czasie około 10 mikrosekund, od zmiany wolnozmiennego sygnału wejściowego. *Może to być punktem wyjścia do próby bardzo efektywnego ataku za pomocą sygnału optycznego o niskim współczynniku wypełnienia degradującego lub uniemożliwiającego świadczenie usługi.*

Przykłady zagrożeń dla sieci rozległych

Ataki na wzmacniacze optyczne

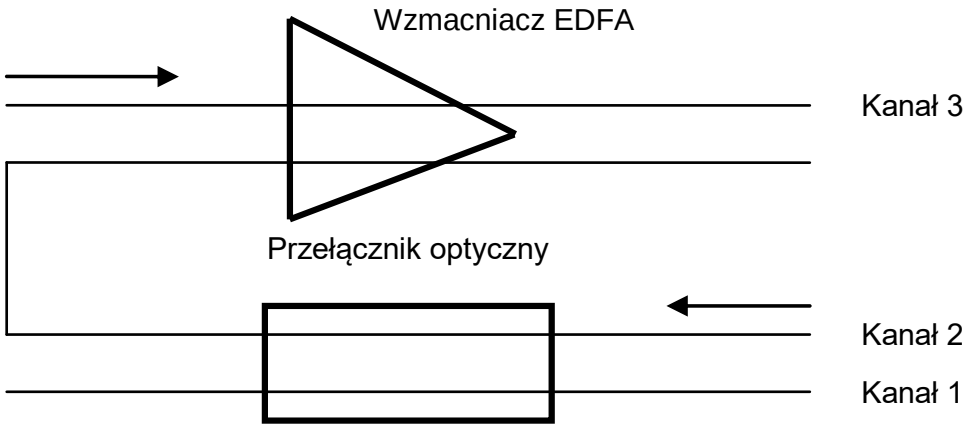
- Przykładem ciekawego ataku, który nie prowadzi do uszkodzenia jest *zatłuszczenie płaszczyzn kontaktu włókien w rozłączalnych połączeniach światłowodów*. Wymaga to chwilowego rozłączenia włókna, ale być może zostanie to zbagatelizowane przez nadzór sieci lub niezauważone, skoro sieć wznowi pracę szybko. Efektem tego będzie *spory wzrost stopy błędów transmisji*, co może uniemożliwić transmisję. Przyczyna nie jest jednak oczywista dla obsługi. Prawdopodobnie podejrzenie padnie na osprzęt transmisyjny (nadajnik, wzmacniacze, multipleksery) ewentualnie włókno, które jednak przy badaniu OTDR nie wykaże uszkodzeń. Być może ekipa naprawcza znajdzie przyczynę, jednak najprawdopodobniej wcześniej straci czas na testowanie sprzętu.

Przykłady zagrożeń dla sieci rozległych

Ataki na demultipleksery optyczne

Ataki na multipleksery optyczne są możliwe gdyż przełączniki optyczne charakteryzują się *większym poziomem przesłuchów* niż ich elektroniczne odpowiedniki (nawet do 1% wobec 0,03% dla przełączników elektronicznych).

Za pomocą przełączników optycznych można dokonać ataku poprzez **zakłócanie sygnałów użytecznych**. Warunkiem jest jednak wprowadzenie do sieci przez intruza sygnału o **dużej mocy**. W wypadku sieci DWDM, dominujących obecnie w sieciach transmisyjnych, nie powoduje to uszkodzenia, gdyż z racji swojej istoty (wiele kanałów, spore odległości transmisji) są przystosowane do wysokich mocy.



Ilustracja propagacji ataku w sieciach optycznych bez regeneracji

Przykłady zagrożeń dla sieci rozległych

Ataki na obiekty teleinformatyczne

Ten rodzaj ataku ma charakter punktowy i prawie zawsze jest rozpoznawalny prawidłowo. Podstawowe scenariusze ataku to:

- fizyczne zniszczenie,
- atak z dołączeniem urządzeń atakującego (wymaga przełamania ochrony biernej i czynnej obiektu),
- atak na interfejsy systemu zarządzania urządzeniami/siecią teleinformatyczną,
- atak na interfejsy (systemy monitorowania/zarządzania) firm będących dostawcami usług/sprzętu teleinformatycznego świadczące usługi zdalne na rzecz operatora teleinformatycznego (obrona: VPN, okna czasowe).
- umieszczenie w pobliżu lub wewnątrz obiektu urządzenia, które w losowo wybranych przedziałach czasu zakłóca pracę wybranych urządzeń teleinformatycznych.

Przykłady zagrożeń dla sieci rozległych

Ataki na sieci komputerowe

Skuteczne ataki na sieci komputerowe **degradują lub uniemożliwiają** pracę **pojedynczych osób, firm, organizacji oraz całych państw**. Z punktu widzenia problemu bezpieczeństwa teleinformatycznego rozróżniamy ataki na:

- pojedyncze komputery,
- sieci komputerowe użytkowników,
- sieci komputerowe dostawców usług transmisyjnych.

Pierwsze dwa podpunkty są oczywiste i nie wymagają objaśnień. Trzeci punkt pojawił się wraz z wprowadzeniem do praktyki koncepcji sieci zarządzania telekomunikacją TMN (ang. *Telecommunication Managment Network*). Jest to **nowa jakość**, gdyż przynajmniej teoretycznie można sobie wyobrazić sytuację, w której na skutek ataku zainicjowanego tylko z jednego komputera sieci korporacyjnej, a **jeżeli sieć korporacyjna ma kontakt z siecią Internet – także z zewnątrz,** dochodzi do dezorganizacji pracy znaczących fragmentów sieci operatora telekomunikacyjnego. Dotychczas takie zdarzenie było prawdopodobne tylko w warunkach katastrofalnych (klęska żywiołowa, działania wojenne itp.).

Przykłady zagrożeń dla sieci rozległych

Ponieważ warstwa transportowa sieci telekomunikacyjnej jest wykorzystywana do tworzenia wielu sieci klienckich, także ogólnodostępnej sieci Internet, to **skuteczny atak na warstwę transportową jest równoznaczny z pozbawieniem infrastruktury teleinformatycznej nie tylko operatora lecz także klientów instytucjonalnych oraz indywidualnych tej sieci.** Zauważmy, że taki atak może sparaliżować **także pracę sieci telefonii komórkowych,** gdyż operatorzy sieci komórkowych dzierżawią często łącza dalekosiężne od operatora dysponującego rozległą warstwą transportową opartą o połączenia optyczne. **Atak na sieć telekomunikacyjną, np. poprzez opanowanie sieci TMN, wydaje się być skuteczną metodą znaczącego osłabienia możliwości gospodarczych państwa.** Ta ostatnia uwaga odnosi się przede wszystkim do krajów, w których jeden operator ma pozycję dominującą w zakresie dostarczania podkładu transmisyjnego dla sieci klienckich. **W rezultacie problem bezpieczeństwa sieci komputerowych staje się także problemem telekomunikacyjnym a nie tylko informatycznym.**

Przykłady zagrożeń dla sieci rozległych

Ataki na sieci komputerowe - hasła

Najprostsza droga do komputera wiąże się bezpośrednio z polem **login i hasłem**. Dlatego duża część ataków jest nastawiona na zdobycie obu. Starsze wersje systemów operacyjnych zawierały wykaz wszystkich haseł w pliku na dysku. Tajność haseł polegała na ukryciu przed użytkownikami nazwy oraz ścieżki owego pliku. Również podczas uwierzytelniania, ścieżka dostępu nie była wyświetlana. Jednak to zabezpieczenie nie jest skuteczne. Obecnie hasła są przechowywane w **postaci wartości funkcji skrótu („hashującej") zależnej od hasła oraz dodatkowych parametrów np. liczby losowej.**

Inną możliwość tworzą błędy (luki) w systemach operacyjnych, wykrywane często po wielu latach. Znaczny procent włamań do systemów następuje z powodu **uchybień w całym systemie haseł.**

Przykłady zagrożeń dla sieci rozległych

Ataki na sieci komputerowe - hasła

Ataki zgadywania haseł przyjmują dwie podstawowe formy.

- **Pierwsza** polega na usiłowaniu zalogowania się za pomocą znanej lub założonej nazwy użytkownika oraz zgadywanego hasła. Ta metoda kończy się sukcesem niezwykle często, ponieważ w wielu miejscach stosuje się parę „nazwa użytkownika-hasło” będących standardowymi.
- **Drugim** sposobem zdobywania haseł przez napastników jest odgadywanie haseł znajdujących się w skradzionych plikach przechowujących. Pliki te kradzione są z systemów, do których już się włamano. W takim przypadku napastnicy będą próbowali zastosować zdobyte hasła w innych komputerach. Użytkownicy często posługują się na różnych komputerach tymi samymi hasłami. Hasła mogą również zostać zdobyte z systemów, które jeszcze nie zostały spenetrowane. Ataki tego rodzaju nazywane są **atakami słownikowymi** i zwykle kończą się pełnym powodzeniem.

Przykłady zagrożeń dla sieci rozległych

Ataki na sieci komputerowe - socjotechnika

Często najstarsze sposoby sprawdzają sie najlepiej. Hasła można znaleźć na kartkach przyczepionych do monitora lub zapisane w dokumentacji leżącej obok klawiatury. Podejście wykorzystujące socjotechnikę zwykle opiera sie na użyciu telefonu i wykazaniu się odrobiną tupetu. Oto przykład przygotowany przez studenta telekomunikacji, pana Tomasza Brzoskiego:

- Witam pani Irenko, mówi Krzysiek z Dziekanatu Wydziału Elektroniki i Telekomunikacji. Mam tutaj pana dziekana Lamperskiego. Pan dziekan prosi mnie o informację, a ja nie mogę w tej chwili skorzystać z mojego komputera, system mi się zawiesił czy coś. Zgasł ekran i nie mogę nic zrobić. Dostałem przed chwilą email od Halinki z 307 zatytułowany „I love You". Jak próbowałem odczytać treść wiadomości, to komputer mi padł. Pewnie wirus. Dałem się nabrać na głupi wirus, ehh. Później będę musiał wezwać informatyka. Czy w związku z tym mogłaby pani poszukać dla mnie informacji o pewnym studencie?
- Oczywiście - odpowiedziała pani Irenka - taki wirus całkowicie zawiesza komputer?
- Niestety, to straszne.
- Jak mogę pomóc?
- Czy może mi pani wywołać konto z systemu?- zapytał włamywacz.
- Tak, jaki jest numer albumu studenta? – zapytała Pani Irenka
- Nie mam numeru, będziemy musieli znaleźć po nazwisku.

Przykłady zagrożeń dla sieci rozległych

Ataki na sieci komputerowe – socjotechnika

Pani Irenka bez chwili zastanowienia odparła:

- Dobrze, proszę podać nazwisko.
- Tomasz Brzoski- po czym włamywacz był na tyle uprzejmy, że przeliterował nazwisko.
- A tak, Brzoski, znalazłam.
- Hmm jest pani pewna, że to właściwy Brzoski? Mogłaby pani podać jego PESEL i adres zamieszkania. Sprawdzę tylko czy to ten.
- 85063286930 to pesel. Adres zamieszkania Lipowa 35, Wąchock.
- Dziękuję, zgadza się. Pan dziekan prosi o informację czy student nadal jest na urlopie dziekańskim.
- Ach tego to nie trzeba było sprawdzać w systemie, pamiętam pana Brzoskiego, urlop ma do końca tego semestru.
- Dziękuję pani, bardzo dziękuję. Do usłyszenia.

Włamywacz odkłada słuchawkę ucieszony, że zdobył potrzebne informacje. Pani Irenka idzie zrobić sobie kawę nieświadoma faktu, że właśnie podała obcej osobie ważne informacje.

Przykłady zagrożeń dla sieci rozległych

Atak socjotechniczny uchodzi obecnie za najskuteczniejszy sposób uzyskania dostępu do chronionych zasobów. Potwierdzają to skuteczne włamania do systemów obronnych lub bankowych wielu państw.

W atakach na sieci komputerowe oprócz dotychczas omówionych metod można wykorzystać nowe. Wspólną cechą nowych metod jest **posługiwanie się specjalistycznymi narzędziami – programami komputerowymi.** Obecnie istnieje **bardzo wiele** klasyfikacji programów nakierowanych na atak. Z perspektywy historycznej możemy podzielić je na:

- **wirusy**
- **bakterie**
- **robaki,**
- **bomby logiczne**
- **konie trojańskie,**

Przykłady zagrożeń dla sieci rozległych

Wirusy komputerowe

Wirus komputerowy to bardzo prosty program komputerowy napisany w celu osłabienia działania systemu komputerowego. Wirusy powielają się samoczynnie, a do rozprzestrzeniania się **potrzebują nosiciela**, tj. innego programu komputerowego. Wirus może być rozprzestrzeniany także jako poczta elektroniczna, złośliwy skrypt na stronie internetowej itp. Wirusy wykorzystują słabość systemu operacyjnego oraz niedoświadczenie użytkownika. Często przez użytkowników komputerów wirusem nazywany jest każdy szkodzący program komputerowy. Ogólnie, wśród wirusów możemy wyróżnić:

- wirusy dyskowe,
- wirusy plikowe,
- wirusy komórkowe,
- wirusy polimorficzne,
- wirusy typu stealth,
- makrowirusy oraz wiele innych.

Przykłady zagrożeń dla sieci rozległych

- Wirusy **dyskowe** były bardzo popularne w erze dyskietek komputerowych. Były to małe programy kopiujące się na dysk twardy wraz z pożądaną zawartością. Systemy operacyjne nie miały wtedy odpowiednich zabezpieczeń. Wirusy szkodziły w różny sposób komputerowi, przy okazji infekowały pozostałe dyskietki użytkownika.
- **Wirusy plikowe są obecnie najpopularniejsze**. Są to krótkie kody wykonywalne programu dołączane do plików posiadanych przez użytkownika komputera. Wirusy te infekują pliki i zasoby sieciowe komputera. Pisane są językiem niskiego poziomu. Wirusy pisane kodem wysokiego poziomu to makrowirusy.
- Wirusy **komórkowe** są obecnie bardzo „popularne”. Infekują systemy operacyjne używane w telefonach komórkowych, głównie system Android, gdyż jest on najbardziej rozpowszechniony. Wirusa takiego można ściągnąć poprzez przeglądarkę internetową zainstalowaną w telefonie bądź wgrywając pliki np. poprzez bluetootha.

Przykłady zagrożeń dla sieci rozległych

- Wirusy **polimorficzne** utrudniają wykrycie przez mutacje, czyli przez modyfikacje swojej zawartości przy kolejnej infekcji.
- Wirusy typu **stealth** potrafią ukryć przed programem antywirusowym zmianę pliku, który został zakażony.
- **Makrowirusy** nie zarażają programów uruchamialnych, lecz dokonują destrukcji dzięki wykonywaniu swojego kodu zapisanego w plikach dokumentów np. Microsoft Office. Są to wirusy bardzo łatwo wykrywalne, a ponadto ich działanie może zostać zablokowane przez programy biurowe np. z pakietu „Office”.

Większość z istniejących wirusów to tzw. **wirusy pasożytnicze**. Pasożytnicze dlatego, że **dołączają się do innych programów i wykorzystują je do transportu**. Wirus taki infekuje program zmieniając i uszkadzając jego strukturę wewnętrzną. Wirusy pasożytnicze możemy podzielić na:

- Wirusy lokujące się na końcu pliku. Dopisują kod wirusa na koniec pliku, a następnie modyfikują początek pliku tak, aby wskazywał na wirusa,

Przykłady zagrożeń dla sieci rozległych

- Wirusy nadpisujące. Lokują się na początku pliku, zwykle nie zapamiętują poprzednich danych w pliku i nieodwracalnie go niszczą,
- Wirusy nagłówkowe. Lokują się w nagłówkach plików EXE,
- Wirusy lokujące się w pliku w miejscach gdzie jest jakiś pusty obszar. Obszar ten wypełniony jest ciągiem zer i można go nadpisać nie niszcząc pliku,
- Wirusy lokujące się w dowolnym miejscu pliku. Są bardzo rzadkie i trudne do napisania.

Wirusy są także częścią innych programów nakierowanych na atak. Przykładem są tzw. **hybrydy.** Są to kombinacje wirusów i różnorodnych automatycznych skryptów atakujących. **Hybrydy instalują się same i rozsyłają się bez problemu omijając zabezpieczenia antywirusowe i zapory ogniowe, wykorzystując słabe punkty systemu oraz usług internetowych**. Poprzez komputery domowe i notebooki hybrydy przenikają do sieci korporacyjnych i domowych, wykorzystując komputery osobiste jako swoiste "stacje przesiadkowe".

Przykłady zagrożeń dla sieci rozległych

Hybrydy wykorzystują **zarówno techniki działania wirusów, jak i techniki włamaniowe.** Hybrydy rozprzestrzeniają się również drogami, takimi jak **systemy czatowe, peer-to-peer i techniki aktywnego włamywania, przy których oprogramowanie antywirusowe jest bezradne**. Działanie systemów antywirusowych, koncentrując się na usuwaniu wrogiego kodu z załączników pocztowych, nie jest skuteczne w przypadku zagrożeń hybrydowych, których istotą jest modyfikowanie systemu operacyjnego komputera w sposób umożliwiający dokonywanie dalszych inwazji. **Hybrydy otwierają kolejne "tylne drzwi", którymi może wniknąć następny intruz**. Podobnie jak programy antywirusowe także zapory ogniowe są tylko częściowym rozwiązaniem, mimo że pozostają krytycznym elementem pierwszej linii obrony.

Przykłady zagrożeń dla sieci rozległych

Bakterie

Bakterie są samodzielnymi programami powielającymi się, których działanie polega przede wszystkim na zużywaniu zasobów systemu, takich jak moc procesora, pamięć, operacyjna i pamięć dyskowa. Duża szybkość autoreplikacji bakterii powoduje szybkie wyczerpanie się zasobów i blokadę systemu.

Robaki

Działanie *robaków* jest podobne do działania bakterii z tym, że ich celem jest zmniejszenie, i/lub blokada pracy nie pojedynczego urządzenia, lecz **sieci urządzeń,** np. serwerów, central cyfrowych itp. Robak to samo rozprzestrzeniający się i samo modyfikujący program komputerowy. Ma podobne działanie do wirusa komputerowego, jednak rożni się od niego tym, że **nie potrzebuje** nosiciela, jest programem samym w sobie. Robak rozprzestrzenia się samoistnie w sieciach komputerowych i w Internecie. Robak może niszczyć pliki, rozsyłać spam z komputera-ofiary bądź pełnić rolę **backddoora** lub konia trojańskiego. Robaki potrafią modyfikować swoją strukturę np. poprzez łączenie się z Internetem i „aktualizację”

Przykłady zagrożeń dla sieci rozległych

Bomby logiczne

Bomby logiczne są to **ukryte nieudokumentowane fragmenty innego programu**, zaprojektowane w taki sposób, że w określonych warunkach następuje aktywacja bomby i realizacja zaprogramowanych czynności. Bomby logiczne **działają jednorazowo** i są wyposażone w „zapalnik". Zadziałanie bomby logicznej może być uwarunkowane różnymi czynnikami, np. określona data, liczba uruchomień programu nosiciela, usuniecie/dodanie pewnej informacji w systemie (pliku, rekordu, itp.).

Koń trojański

Koń trojański to określenie oprogramowania, które podszywając się pod przydatne lub ciekawe dla użytkownika aplikacje dodatkowo implementują niepożądaną, ukrytą przed użytkownikiem funkcjonalność.

Przykłady zagrożeń dla sieci rozległych

Wymienione do tej pory złośliwe oprogramowanie można nazwać oprogramowaniem „ogólnego przeznaczenia". Oprócz tego istnieje bardzo wiele programów realizujących konkretne cele, np. otwarcie tylnych drzwi, szpiegowanie, poznanie sekwencji wciśniętych klawiszy. Większość z nich to konie trojańskie realizujące konkretną funkcję. Przykłady to:

- **BackDoor („Tylne drzwi")** to **luka w zainstalowanym oprogramowaniu** umożliwiająca oddziaływanie na komputer/sieć **przez osoby trzecie**. BackDoora nabywamy często instalując oprogramowanie, które zachęca nas ciekawymi funkcjami. Instalując program otwieramy także furtkę dla hakera.
- **Rootkit** jest to narzędzie pomocne do włamań na systemy operacyjne. Ukrywa ono w sobie niebezpieczne pliki i procesy, które przejmują kontrolę nad systemem komputerowym. Rootkit infekuje system i **ukrywa** program (**np. wirusa**) przed administratorem oraz programem antywirusowym. Rootkit przedostaje się na dysk użytkownika poprzez wybraną aplikację.

Przykłady zagrożeń dla sieci rozległych

- **ForkBomb** – jest to forma ataku przeciwko systemowi komputerowemu. Polega na tym, że blokuje zasoby systemowe poprzez uruchomienie wielokrotnie tych samych procesów. ForkBomb nie rozprzestrzenia się jak wirus czy robak. Do obezwładniania systemu wykorzystuje fakt, ze liczba programów czy procesów na komputerze osobistym użytkownika, nie może być wykonywana bez limitu. Ten tym złośliwego oprogramowania możemy uważać, do pewnego stopnia, za połączenie koncepcji bakterii i bomby logicznej.
- **Spyware** jest to oprogramowanie zbierające informacje o użytkowniku komputera bez jego zgody. Występuje często jako dodatkowe i ukryte komponenty większego programu, odporne na usuwanie i ingerencję użytkownika. Do oprogramowania szpiegującego zaliczamy na przykład:
  - Adware
  - Stealware
  - Keyloggery

Przykłady zagrożeń dla sieci rozległych

Adware to legalne, często licencjonowane, oprogramowanie, które zazwyczaj nieodpłatnie jest oferowane użytkownikowi Internetu. Program ten ma jednak zaprogramowaną w sobie funkcję wyświetlania reklam. Wydawca oferując nieodpłatne oprogramowanie zarabia właśnie na reklamach. Do adware można zaliczyć także oprogramowanie, które wyświetlając reklamy utrudnia pracę na komputerze. Adware może także poprzez ukryte funkcje wysyłać do Internetu dane o systemie takie jak wersja systemu operacyjnego, najczęściej oglądane strony internetowe itp.

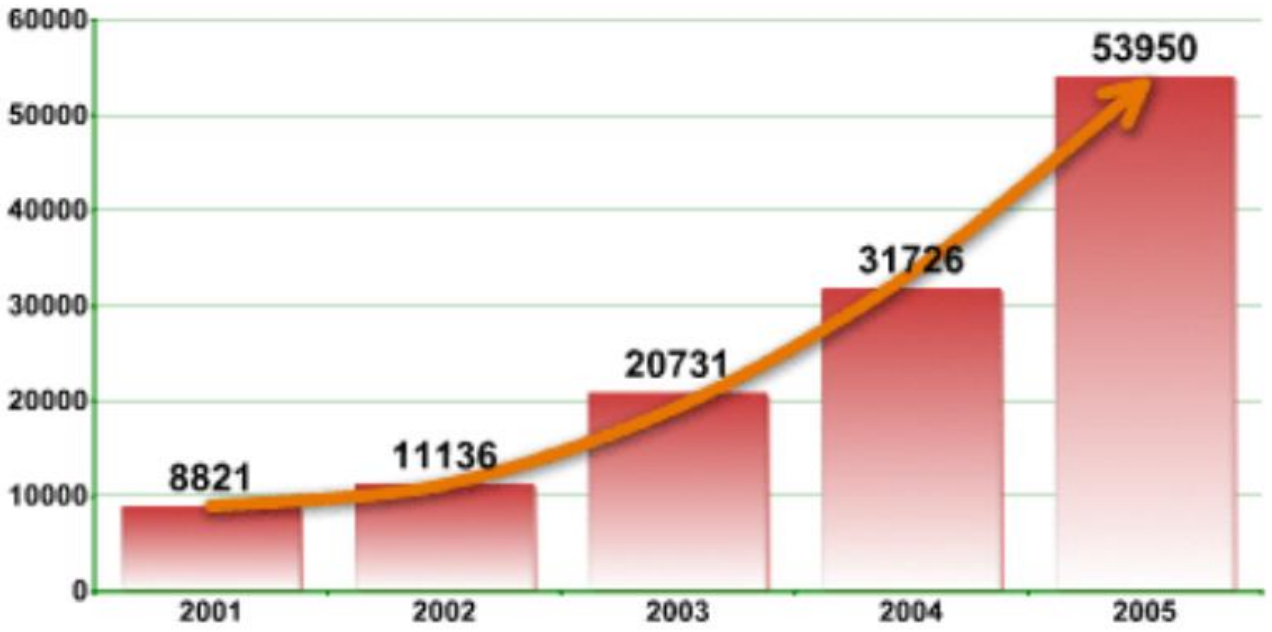
Stealware to program komputerowy, którego celem jest śledzenie użytkownika w sieci w celu wychwycenia informacji o płatnościach poprzez Internet. Oprogramowanie takie obserwuje poczynania internauty i w chwili, kiedy stwierdzi próbę płatności podmienia numer konta na inny. Oprogramowanie takie jest instalowane bez zgody użytkownika, wykorzystując najczęściej błędy w przeglądarkach internetowych.

Keylogger to program, który służy do rejestrowania sekwencji wciśniętych klawiszy klawiatury komputerowej. Program taki przejmuje kontrolę nad odpowiednimi zasobami systemu, które służą do obsługi klawiatury. Każde naciśnięcie przycisku klawiatury jest zapisywane w pliku, który jest z reguły ukryty przez użytkownikiem. Keyloger służy do przechwytywania haseł, loginów itp.

Przykłady zagrożeń dla sieci rozległych

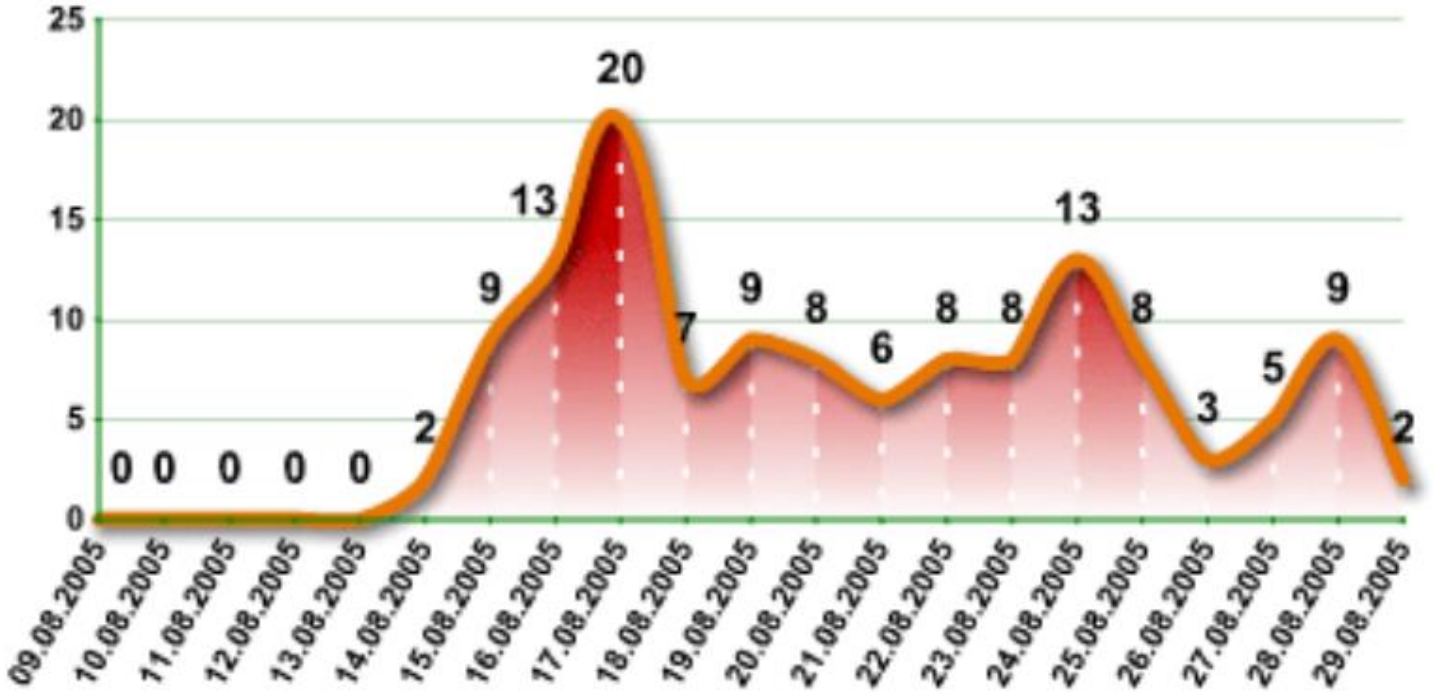
- **Dialery –** to programy komputerowe, które przełączają połączenie internetowe ze standardowego taniego numeru na numer o wielokrotnie podwyższonych kosztach.
- **Malware -** to ogólna nazwa programów tworzonych dla osiągniecia *konkretnych korzyści* np. finansowych (tzw. business – malware). Może to być kradzież danych istotnych dla firmy, które można wykorzystać dla osiągnięcia korzyści finansowych.
- **I dziesiątki innych…**

Przykłady zagrożeń dla sieci rozległych



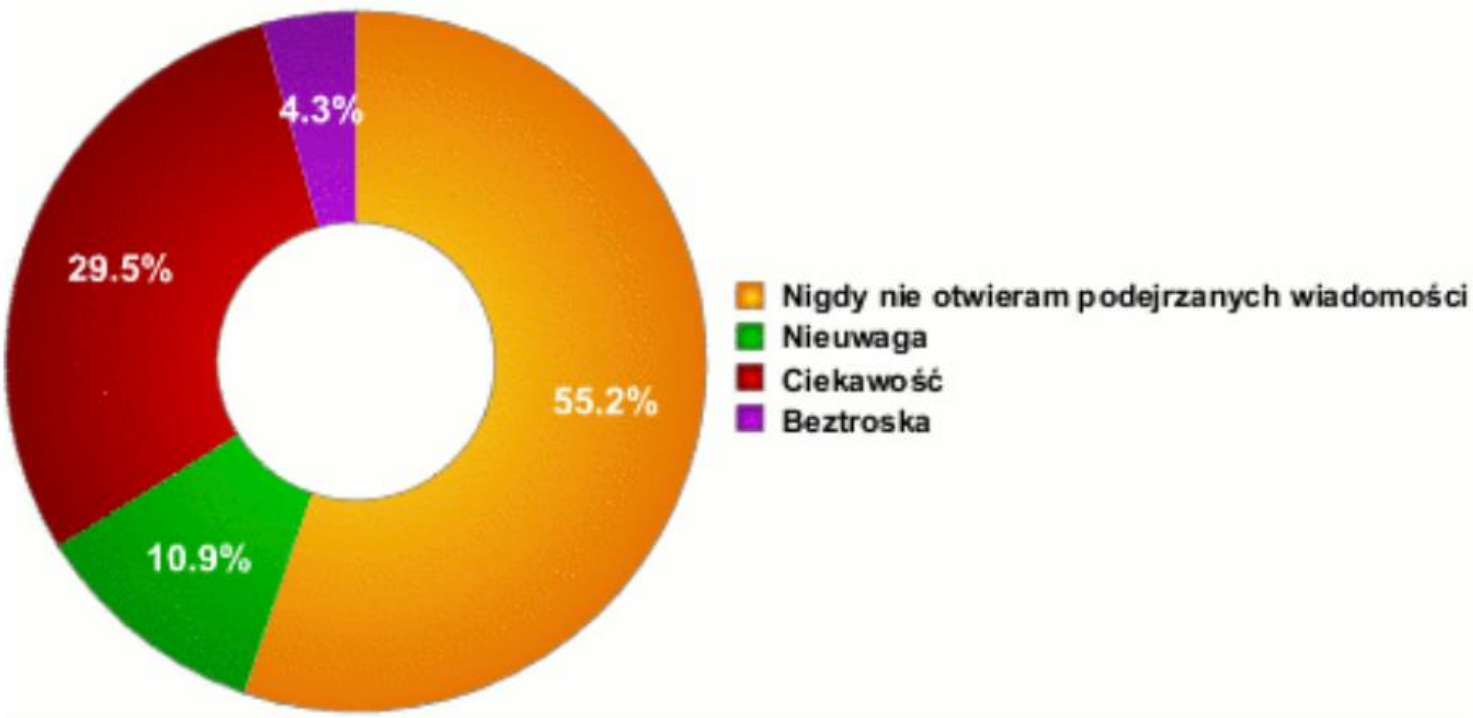
Liczba złośliwych programów wykrywanych w latach 2001-2005 (na podstawie danych z witryny http://kaspersky.pl.)

Przykłady zagrożeń dla sieci rozległych



Liczba różnych rodzajów złośliwych programów wykorzystujących lukę MS05-39 w ciągu jednego dnia (nazwa firmy Microsoft, dotyczy Win32) (sierpień 2005), na podstawie danych z witryny http://kaspersky.pl

Przykłady zagrożeń dla sieci rozległych



Wyniki ankiety pt. „Dlaczego otwierasz podejrzane wiadomości” przeprowadzonej wśród użytkowników programu Kasperski Lab.

Przykłady zagrożeń dla sieci rozległych

Jednym z najczęstszych ataków wykorzystujących specjalizowane oprogramowanie jest atak polegający na **blokowaniu usług** (atak typu DoS – ang. *Denial of Service*) na system komputerowy lub sieć komputerową w celu uniemożliwienia jej działania poprzez zajęcie wszystkich wolnych zasobów. Przeprowadzany równocześnie z wielu komputerów jest określany jako atak DDoS – ang. *Distributed Denial of Service*, rozproszona blokada usługi. **Do ataku wykorzystywane są często pakiety zawierające sfałszowane, wybrane losowo (wobec czego bezużyteczne) adresy źródłowe.**

Do przeprowadzenia rozproszonego ataku odmowy usługi DDoS, wykorzystywanych jest wiele komputerów spiętych w sieć **botnet** (sieci botnet to połączone ze sobą komputery, na których zainstalowano aplikacje wykorzystywane do rozsyłania spamu i atakowania witryn internetowych). Najczęściej komputery te uczestniczą w ataku zupełnie bezwiednie, gdyż w jakiś sposób wcześniej włamano się i umieszczono w nich złośliwy program. Bardzo trudno jest uwolnić się od ataku DDoS, gdyż atak następuje ze wszystkich stron.

Przykłady zagrożeń dla sieci rozległych

Atak polega na **bombardowaniu komputerów lub witryn internetowych strumieniami wrogich pakietów danych lub e-mailami**.

Kolejne kroki tego ataku przedstawiają się następująco:

- Napastnik za pomocą odpowiednich środków instaluje program, tzw. „zombi” na wielu komputerach.
- Program „zombi” wiąże się z jednym z portów i oczekuje instrukcji.
- Napastnik instaluje program główny w jednym z komputerów w Internecie. Program główny dysponuje listą komputerów, na których zainstalowane są wszystkie programy „zombi”.
- Napastnik czeka.
- Kiedy nadchodzi czas ataku, napastnik wysyła programowi głównemu komunikat, w którym przekazuje mu adres celu ataku.
- Wszystkie programy „zombi” jednocześnie wysyłają w kierunku celu taką liczbę pakietów, która go blokuje.

Przykłady zagrożeń dla sieci rozległych

Na skutek ataku DDoS system komputerowy ofiary przestaje się nadawać do użytku, co w przypadku większości internetowych detalistów prowadzi do bardzo poważnych trudności i szkód. Straty spowodowane tego rodzaju atakami są bardzo wysokie — ofiara nie może prowadzić żadnej działalności internetowej aż do momentu ustania skutków ataku. Atakowi takiemu towarzyszą często żądania pieniężne noszące znamiona wymuszenia, co dodatkowo podnosi koszty całego zdarzenia. W październiku 2005 roku trzech Holendrów oskarżonych zostało o „zhakowanie" około **półtora miliona komputerów** rozlokowanych w różnych punktach na całym świecie i połączenie ich w jedną sieć botnet. Oszuści wykorzystali tę sieć komputerów „**zombi**" do kradzieży numerów kart kredytowych i innych danych osobowych oraz do szantażowania firm internetowych.

Atak DDoS często jest połączony z żądaniem okupu (cyberwymuszenie). Tworzenie wirusów w celu wymuszania pieniędzy nie jest zjawiskiem nowym. Mamy z nimi do czynienia przynajmniej od roku 1989. Jednak w ostatnich latach twórcy wirusów rzadziej tworzą wirusy po to, by zademonstrować swoje szczególne umiejętności, częściej natomiast kieruje nimi motywacja czysto finansowa.

Przykłady zagrożeń dla sieci rozległych

Ataki DoS i DDoS są przykładami tzw. **ataków lawinowych**. W atakach lawinowych wykorzystywane są samo rozprzestrzeniające się programy, do powielenia których dochodzi bardzo szybko (wirusy, bakterie i robaki). Matematyczne funkcje ich rozprzestrzeniania są podobne, a różnice miedzy nimi nie są ważne. Epidemiologia takich programów jest podobna do infekcji biologicznych. **Sukces działania tych programów polega na wykorzystywaniu powszechnych błędów lub zachowań występujących w wielkich populacjach i podatnych na to programów oraz użytkowników**. Mogą się rozprzestrzenić na cały świat **w ciągu kilku godzin**, a potencjalnie, nawet w ciągu kilku minut. **Rozprzestrzeniając się w dużych społecznościach, mogą powodować olbrzymie szkody ekonomiczne**.

Specyficzną odmianą ataku wykorzystującego specjalizowane oprogramowanie jest tzw. **wardriving.** Rozwój tej techniki związany jest z upowszechnianiem się tanich sieci bezprzewodowych, których koszty utrzymania są nieustannie redukowane. Po ulicach miast krążą **cyberszperacze** ze standardowymi laptopami lub komputerami przenośnymi przystosowanymi do komunikacji bezprzewodowej i wyposażonymi w odpowiednie oprogramowanie, które można za darmo pobrać z Internetu. **Programy te poszukują niezabezpieczonych sieci bezprzewodowych, do których mogą się bezpośrednio podłączyć.** Krążące w takiej sieci informacje są zapisywane w urządzeniu oszusta, a następnie sprzedawane konkurentom firmy, z której zostały pozyskane.

Przykłady zagrożeń dla sieci rozległych

Do podstawowych zagrożeń związanych z **pocztą elektroniczną** można zaliczyć **przede wszystkim**:

- Spam
- Niebezpieczne załączniki poczty
- Poczta w formacie HTML
- **Phishing**

Mianem **spamu** określamy niechcianą i niepotrzebną pocztę elektroniczną. Są to najczęściej listy rozsyłane masowo, kierowane do anonimowego odbiorcy. Zawierają informacje, których adresat nie oczekiwał, przy czym ich przydatność dla odbiorcy ma drugorzędne znaczenie. Przykładem są tzw. łańcuszki szczęścia, fałszywe ostrzeżenia, którym często towarzyszy prośba o przeslanie takiego ostrzeżenia znajomym oraz oferty i reklamy – dzisiaj często spersonalizowane dzięki plikom **„cookies”**. Powinniśmy wystrzegać się publikowania na stronach WWW jakichkolwiek adresów e-mail, ponieważ automaty do zbierania adresów zbierają je stamtąd. Jeśli już to robimy, zapisujemy adres **nie** w postaci tekstowej, a w **formie pliku graficznego** (gif/jpg) lub też odpowiednio go zapisując np. zamiast user@domena.pl można napisać **user (at) domena.pl**.

Przykłady zagrożeń dla sieci rozległych

Do **niebezpiecznych załączników poczty** możemy zaliczyć przede wszystkim:

- Pliki wykonywalne - .exe, .bat, .pif,
- Pliki ze skryptami - .doc, docx, .xls, .ppt, pptx.

Załączniki mogą zawierać groźne dla naszego komputera (głównie danych na nim zgromadzonych) wirusy, a także programy szpiegujące (spyware), gromadzące informacje o użytkowniku i wysyłające je często bez jego wiedzy i zgody autorowi programu. Do takich informacji należeć mogą:

- Adresy stron www odwiedzanych przez użytkownika
- Dane osobowe
- Numery kart płatniczych
- Hasła
- Adresy poczty elektronicznej

Większość programów pocztowych posiada funkcję blokady niebezpiecznych załączników poczty, jednak najczęściej jest to funkcja uciążliwa – blokuje wszystkie załączniki poczty o określonym rozszerzeniu, nawet jeśli nie zawierają one wirusów/spyware itp. Do wykrywania, usuwania i zwalczania niebezpiecznych programów służą różne programy. Najlepszym jednak sposobem jest **nie otwieranie załączników poczty w mailu nieznanego pochodzenia, albo używanie do tego celu tzw. komputera „śmieciowego”.**

Przykłady zagrożeń dla sieci rozległych

Poczta w formacie HTML

Wielu użytkowników poczty elektronicznej wysyła wiadomości w formacie HTML bez istotnych powodów czy korzyści. Zazwyczaj jedyną przyczyną jest „ładny wygląd”. W wiadomościach HTML można stosować kolorowe tła lub ciekawą czcionkę. Mogą one zawierać też różne ozdobniki, dodawane do wiadomości w postaci grafiki. Niestety, poczta w formacie HTML **jest wysoce ryzykowna z punktu widzenia bezpieczeństwa.** W wiadomościach HTML można łatwo zawrzeć niepożądane, zafałszowane linki, pluskwy webowe, różnego rodzaju aplety, skrypty oraz robaki lub wirusy. Inne nieszczelności, właściwe dla poczty HTML, to zdolność uruchamiania skryptów Visual Basic, apletów ActiveX i Macromedia Flash. Wszystkie te twory mogą wykonywać nieautoryzowane i niebezpieczne akcje. Niektóre organizacje i indywidualni użytkownicy blokują całkowicie wiadomości HTML. Blokowanie wchodzącej poczty HTML jest stosunkowo proste, ponieważ zawiera ona rozpoznawalny ciąg znaków związany z HTML. Tam, gdzie nie jest to konieczne **zaleca się rezygnacje z formatu HTML jako domyślnego dla poczty wychodzącej i wysyłanie poczty w zwykłym tekście.**

Przykłady zagrożeń dla sieci rozległych

Phising

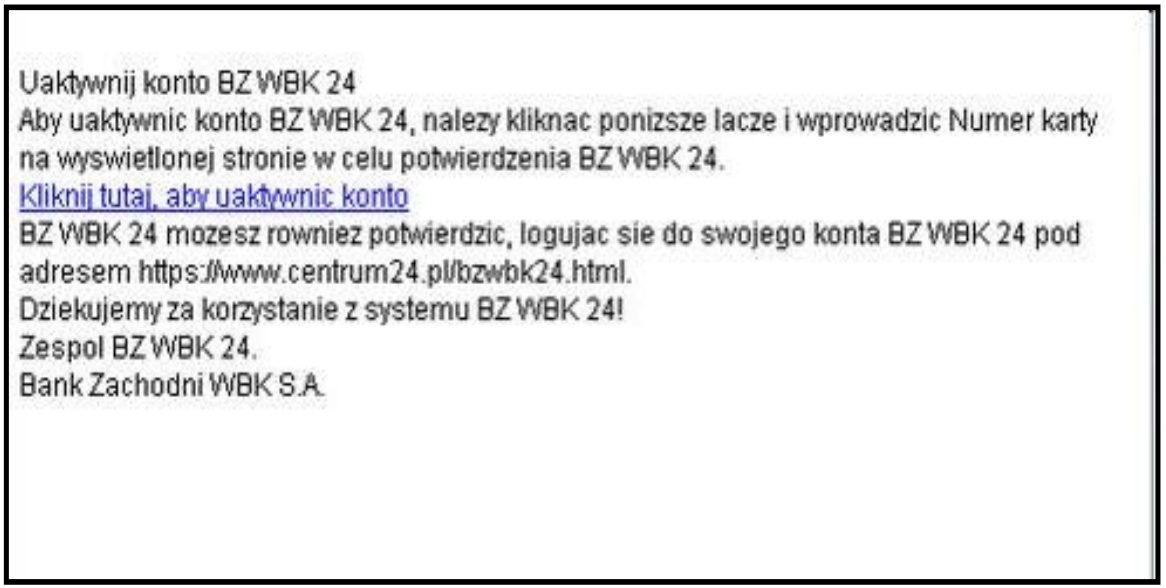
Phising to próba **nieuczciwego pozyskania danych osobowych oraz haseł, które otwierają przestępcom drogę do naszych kont w bankach, sklepach oraz innych instytucjach, głównie finansowych**. Przestępca zwykle podszywa się pod przedstawiciela instytucji finansowych próbując nakłonić odbiorców e-maili do przesłania im haseł oraz innych danych osobowych, bądź pilnej aktualizacji swoich danych na spreparowanej fałszywej stronie internetowej banku, która zbiera nasze dane dostępowe do prawdziwej witryny instytucji finansowej.

Skuteczną obrona przed phisingiem jest **NIE KLIKANIE** na link podany w emailu. Jeśli istnieje znaczące prawdopodobieństwo, że treść wiadomości jest prawdziwa, to należy uruchomić przeglądarkę internetową i **ręcznie wprowadzić znany nam adres strony (bez copy-paste łącza podanego w emailu).** Niektórzy specjaliści zalecają wręcz ponowne uruchomienie komputera a następnie przeglądarki i ręczne wprowadzenie znanego nam adresu strony.

Przykłady zagrożeń dla sieci rozległych

Phishing – przykład z 25.03.2008 r.

Wielu internautów dostaje wiadomości z linkiem do strony łudząco podobnej do oficjalnej witryny banku BZ WBK, gdzie próbuje się ich nakłonić do podania numeru karty kredytowej i numeru PIN.



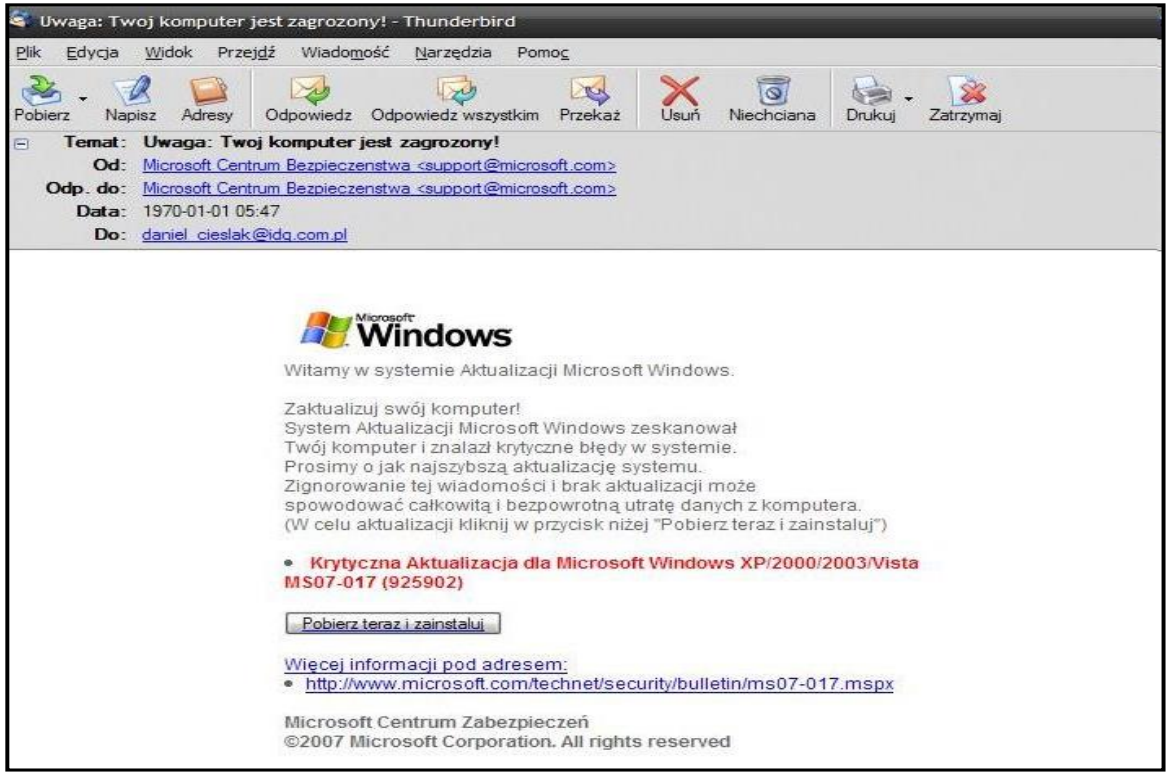
Uaktywnij konto BZ WBK 24
Aby uaktywnic konto BZ WBK 24, nalezy kliknac ponizsze lacze i wprowadzic Numer karty na wyswietlonej stronie w celu potwierdzenia BZ WBK 24.
Kliknij tutaj, aby uaktywnic konto
BZ WBK 24 mozesz rowniez potwierdzic, logujac sie do swojego konta BZ WBK 24 pod adresem https://www.centrum24.pl/bzwbk24.html.
Dziekujemy za korzystanie z systemu BZ WBK 24!
Zespol BZ WBK 24.
Bank Zachodni WBK S.A.

Po kliknięciu na podane łącze adresat maila przenoszony jest do podstrony, gdzie prosi się go o podanie numeru karty, daty jej ważności oraz numeru PIN. Chociaż strona wygląda bardzo profesjonalnie i jest łudząco podobna do oryginalnych stron BZ WBK, to już jej adres może budzić wątpliwości. W rzeczywistości jest ona umieszczona na serwerze **kolumbijskiego szpitala**.

Przykłady zagrożeń dla sieci rozległych

Phishing – przykład z 16.04.2007 r.

Na slajdzie widać odnośnik, umożliwiający jakoby pobranie poprawki opisanej w biuletynie MS07-017 (takie oznaczenie nosi jedna z łat (ang. *patch*) udostępnionych 3 kwietnia przez Microsoft) - jednak kliknięcie na niego powoduje przekierowanie przeglądarki na stronę o adresie podobnym do serwisu Microsoft Update. Po chwili następuje przekierowanie na kolejną stronę, na której umieszczony jest koń trojański.



Bibliografia:

1. A. Białas, *Bezpieczeństwo informacji i usług w nowoczesnej instytucji i firmie*, WNT, Warszawa, 2007.
2. K. Liderman, *Analiza ryzyka i ochrona informacji w systemach komputerowych*, PWN, Warszawa, 2008.
3. K. Liderman, *Bezpieczeństwo informacyjne, nowe wyzwania*, PWN, 2017.
4. R. Andersson, *Inżynieria zabezpieczeń*, WNT, 2005.
5. J. Stokłosa, T. Bilski, T. Pankowski, *Bezpieczeństwo danych w systemach informacyjnych*, PWN, 2001.
6. Materiały firmowe/Internet.

KONIEC CZĘŚCI I